Setup

https://github.com/rpigu-i/sans-offensive-ai-in-practice-april-2026

Offensive AI in Practice

Hands-on exploitation of vulnerable applications using open source AI tools

3-hour workshop deck redesigned for paced facilitation, live coding, and agent runs

180 MIN | **3 LABS** | **45-MIN CODING BLOCKS**

Audience: students running vulnerable apps locally in Docker, then comparing traditional scanning with AI-backed offensive workflows.

Workshop arc and pacing

Built around short framing segments plus three sustained build-and-run blocks

Intro + trainer framing	5 min
Format + environment check	5 min
How AI changes offensive security	10 min
Lab 1 · Deploy Juice Shop	10 min
Lab 2 · ZAP baseline	**45 min**
Lab 3 · Shannon agent	**45 min**
Lab 4 · PentestGPT	**45 min**
Scaling discussion	10 min
Wrap-up + questions	5 min

Facilitation rhythm

Objective framing

25–30 minutes of keyboard time

10–15 minutes for debugging + comparison

Outcomes and requirements

What students should leave with after the session

Learning outcomes

- Understand how AI compresses recon, analysis, and exploit iteration
- Run one traditional scanner and two AI-assisted offensive tools locally
- Compare the quality of findings, speed, and operator burden
- Recognize why operationalizing open source offensive AI is hard in enterprise settings

Student checklist

- Docker Desktop installed and validated
- Terminal access and Git installed
- Browser available for Juice Shop and dashboards
- Anthropic API key configured
- GitHub account ready for the workshop bundle

```
docker --version
docker run hello-world
export ANTHROPIC_API_KEY=your_key_here
```

How AI changes the attack loop

The key message: AI amplifies attacker capability, speed, and scale

Traditional model

- Reconnaissance
- Vulnerability discovery
- Exploit research or development
- Exploitation
- Privilege escalation or lateral movement

Often measured in hours to weeks.

AI-augmented model

- Endpoint discovery
- Parameter analysis
- Exploit generation
- Payload crafting, testing and iteration
- Vulnerability chaining

Machine-speed iteration compresses the cycle to minutes or hours.

Workshop tool stack

Open source tooling, commercial model backend, and containerized execution

Target

OWASP Juice Shop

- Modern SPA with login, APIs, and common web vulns

Traditional tool

OWASP ZAP baseline

- Fast benchmark for what a non-agent scan catches first

AI-assisted tools

Shannon

PentestGPT

- Both run in containers and use Anthropic-backed reasoning

Delivery model: the repo provides bootstrap code, Docker Compose starts the app + tools, and each lab ends with a compare-and-debrief moment.

Lab 1 · Deploy the vulnerable target

10 MIN

10-minute setup segment before the three major coding blocks

SETUP + VALIDATION

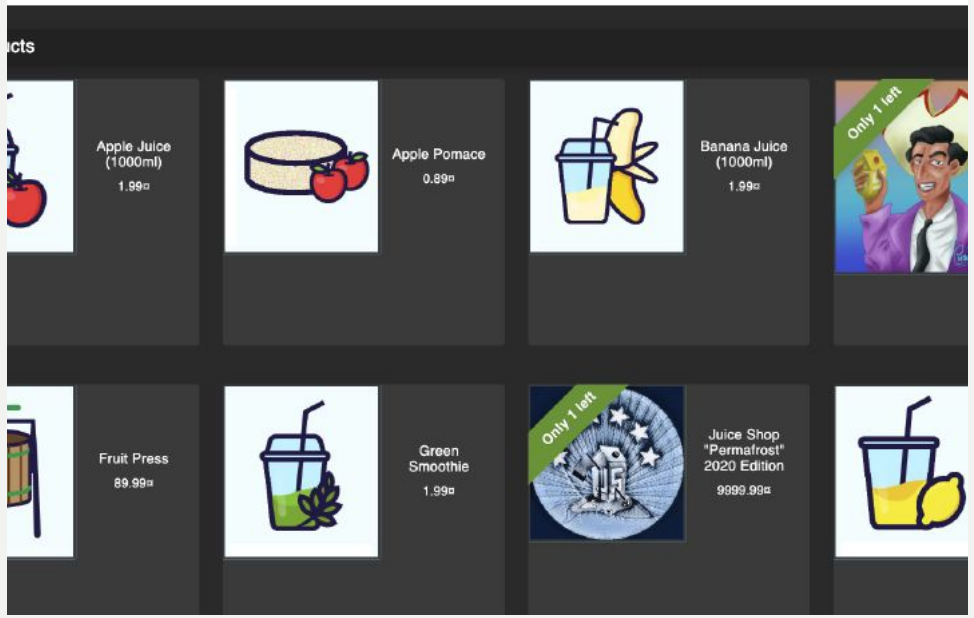
Target: OWASP Juice Shop

Modern single-page app

Intentionally vulnerable

- Good coverage for IDOR, auth flaws, injection, and access control issues

```
cd workshop-bundle
cp .env.example .env
# add ANTHROPIC_API_KEY
docker compose up -d
```



Confirm the app opens at localhost:3000 before moving on.

Lab 2 · ZAP baseline

45 MIN

Traditional DAST first, so students have a comparison point before they run agents

CODING BLOCK 1

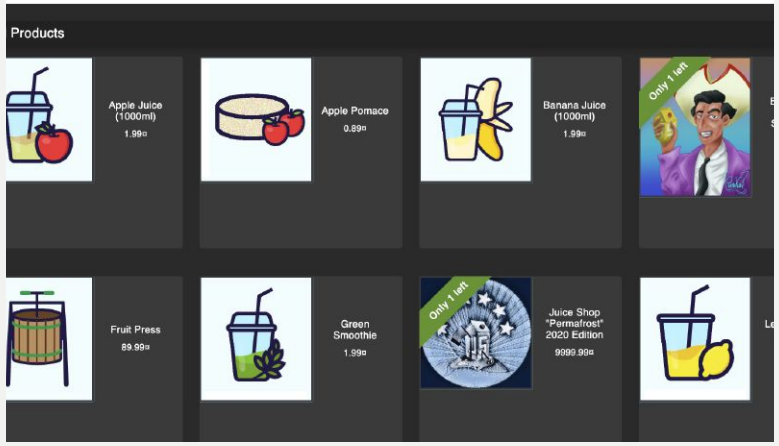
Run

```
docker compose run --rm zap-baseline
```

What to observe

- Baseline scanner output and HTML report
- Likely focus on straightforward endpoints and patterns
- Use a simple IDOR example to show where manual reasoning still matters

```
curl
http://localhost:3000/rest/basket/2
```



Debrief question: what did ZAP find quickly, and what still required analyst interpretation?

Lab 3 · Shannon agent workflow

45 MIN

Students move from scanning to an agent that stores findings and reasons over responses

CODING BLOCK 2

Why Shannon

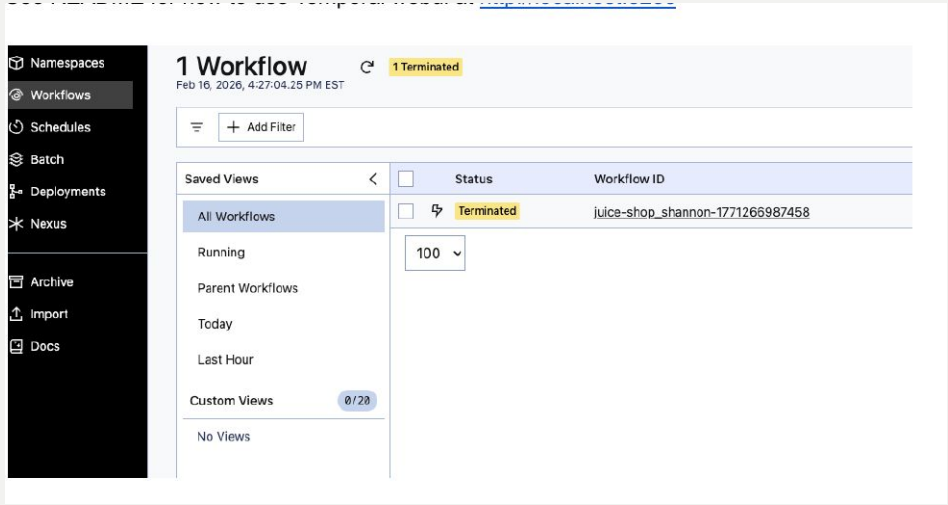
Identifies insecure endpoints

Analyzes responses

- Generates exploit strategies and writes findings to a repo-backed workspace

```
docker compose ps
mkdir -p workspace/juice-shop
cd workspace/juice-shop && git init
```

```
docker compose exec shannon-worker node dist/temporal/client.js \
http://juice-shop:3000 /app/repos/juice-shop --config /app/configs/juice-shop.yaml --wait
```



Lab 4 · PentestGPT

45 MIN

The final block emphasizes end-to-end pentest workflow assistance and generated commands

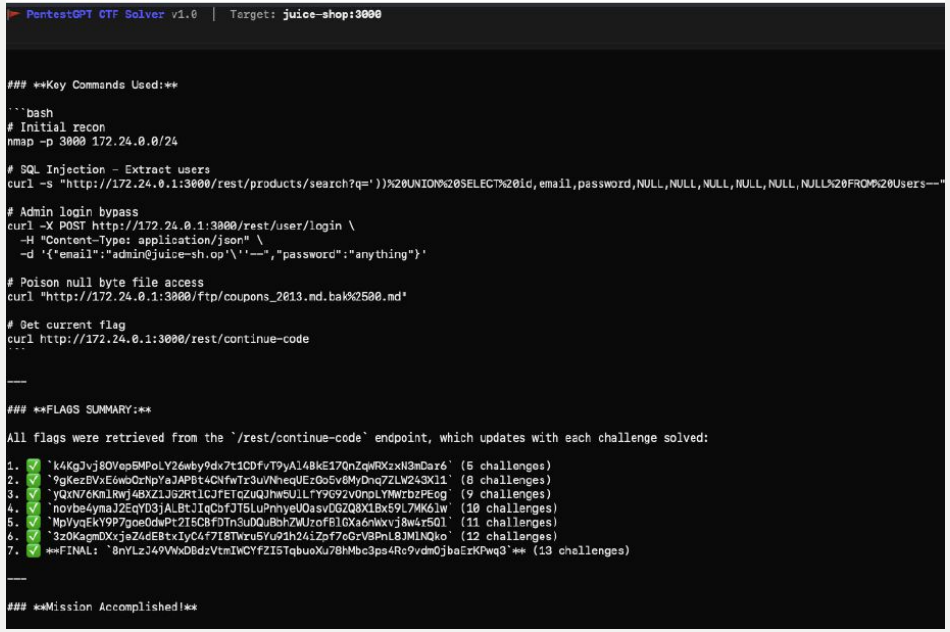
CODING BLOCK 3

Run

```
docker compose exec -it pentestgpt bash
pentestgpt --target juice-shop:3000
```

What students compare

- Endpoint enumeration
- Suggested exploits
- Command generation
- How much analyst steering is still needed



Reminder: validate findings inside Juice Shop rather than treating model output as automatically correct.

Cross-lab comparison

Use this slide to debrief after the final coding block

Dimension	ZAP baseline	Shannon	PentestGPT
Setup burden	Low	Medium	Medium
Autonomy	Low	High	High
Output style	Scanner report	Repo + workflow traces	Interactive pentest guidance
Best teaching use	Baseline and control	Reasoning over app behavior	**Operator-in-the-loop experimentation**

Prompt: Which workflow would you trust first in a real assessment, and which one created the most useful analyst leverage?

Why open source offensive AI is hard to scale

This is the enterprise lens that closes the workshop

Infrastructure complexity	GPU compute, scaling, API management
Reliability	Open source models can be less consistent and require tuning
Enterprise requirements	Audit logging, authentication, RBAC, compliance
Operational overhead	Containers, models, updates, and security risk management

Key takeaway: powerful open source tools exist, but commercial platforms are gaining ground because they reduce operational friction.

Final wrap-up

Leave students with the attacker model, not just the tools

Key takeaways

AI is transforming offensive security by collapsing recon and exploit iteration time

Traditional scanning still matters as a baseline and validation layer

Agentic tools can accelerate workflows, but they need analyst oversight

Defenders need firsthand familiarity with offensive AI to defend effectively

Q&A · 5 MIN

“What changed most for you today: speed, confidence, or the amount of manual work?”